Instructions

Answer the assignment question through the two sub-questions below. Each sub-question carries 5 marks. Apply the concepts to the scenario rather than reproducing definitions.

Keep your submission to approximately 2 to 3 pages, including any tables.

No coding, tool installation, live scanning or exploitation is required.

The supplied observations are sufficient.

Scenario

A university has developed a mobile application that connects to a cloud-hosted student portal through an API. Before deployment, the university requests an ethical-hacking assessment of an isolated staging environment containing only synthetic student records.

The university has offered a staging web server, the API and two ordinary student test accounts, A and B, for assessment. Written authorization and detailed testing limits must still be agreed before any hands-on work begins.

The development team supplies the following fictional observations from its own staging checks:

| Observation | Details |

|---|---|

| O1: Network services | A service inventory lists SSH on TCP port 22 and HTTPS on TCP port 443 as reachable from the staging test network. |

| O2: API access | While signed in as test student A, a tester changed a record identifier in a request and received the synthetic academic record belonging to test student B. |

| O3: Cloud permissions | The application's service role can read every storage bucket in the staging cloud account, although the application requires access to only one bucket. |

| O4: Authentication logs | A test account recorded 20 failed login attempts in two minutes, followed by a successful login. The identity of the person generating these events has not been confirmed. |

Production systems, real student data, third-party services and other university networks are outside the proposed scope. An open port or a successful login alone does not establish that a compromise occurred.

Assignment question

As an ethical hacker, prepare a short assessment plan and recommendations for this university. Use the supplied observations to answer both parts.

(a) Ethical assessment planning and identification of weaknesses [**5 marks**]

State what written permission and testing boundaries must be agreed before assessment begins. Include one activity that must not be performed under the proposed scope. *[1 mark]*

Distinguish passive reconnaissance from active reconnaissance and give one suitable example of each for this assessment. Describe the examples only; do not execute them. *[2 marks: 1 mark per approach]*

Identify two security weaknesses supported by the observations. For each, cite the observation, explain the weakness and describe a plausible security impact. Do not classify an exposed service as a vulnerability without additional evidence. *[2 marks: 1 mark per finding]*

(b) Safe validation, remediation and defensive monitoring [**5 marks**]

For each weakness identified in part (a), describe one safe validation check using the staging environment and synthetic records. State the expected secure result so that the university can determine whether the weakness has been fixed. These are proposed checks, not tests you must execute. *[2 marks: 1 mark per check]*

Recommend one specific corrective control for each weakness and explain how it reduces the risk. Identify which of the two findings should be addressed first and briefly justify your choice. *[2 marks]*

Using O4, propose one simple SIEM alert rule and one initial investigation or containment action. Explain why the event sequence warrants investigation but does not, by itself, prove an account compromise. *[1 mark]*

Note: Credit is awarded for clear reasoning, evidence-based findings and feasible recommendations. Alternative well-justified answers are acceptable; actual attacks, screenshots of tools and advanced exploit development are not required.